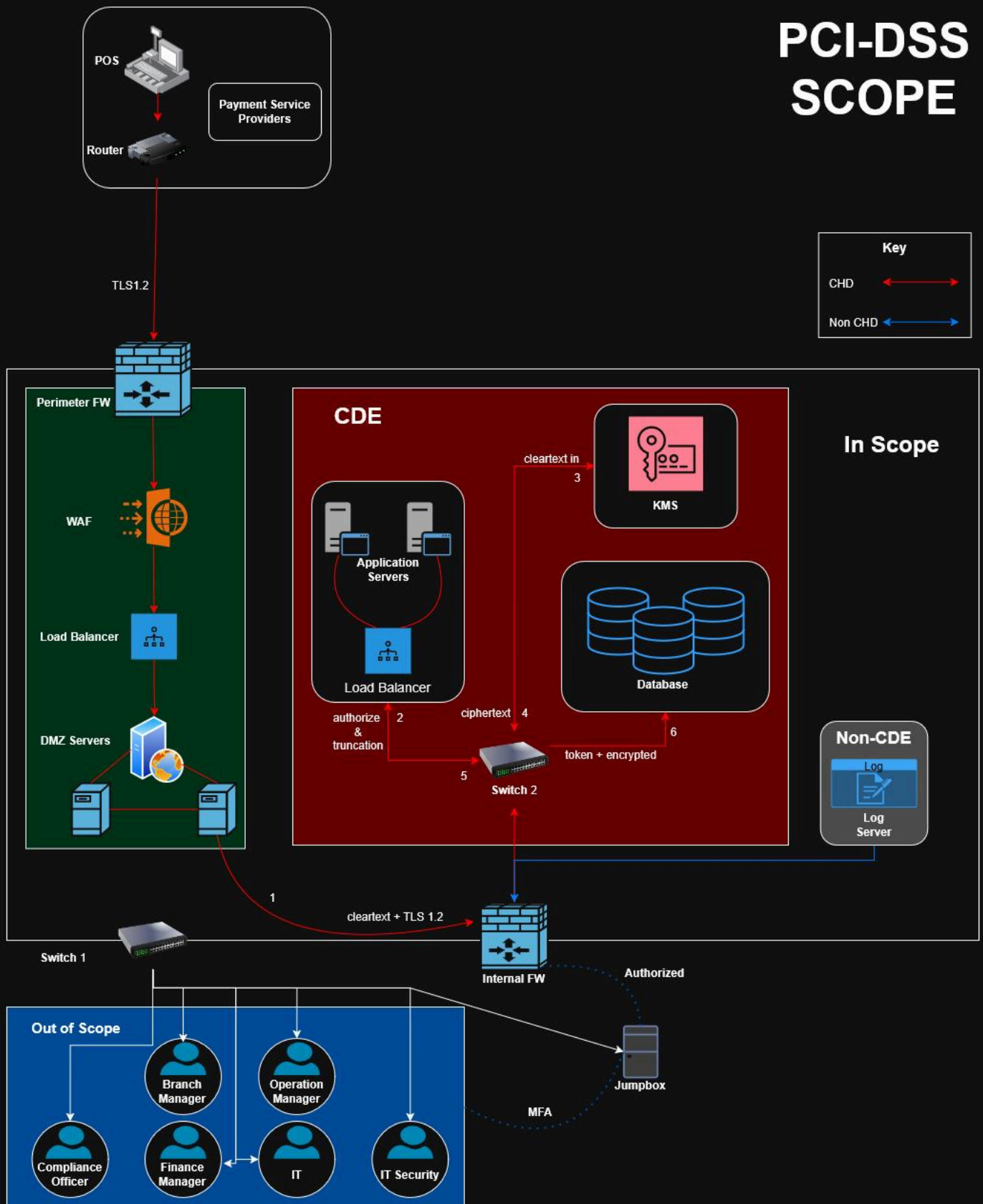


Inventory Asset

ID	Name / Component	Vlan	IP / Subnet
Retailer			
1	Retailer POS	VLAN 10 (Store)	192.168.10.20/24
2	Retailer Router	VLAN 10 (Store)	192.168.10.1/24
Firewalls & DMZ			
3	Perimeter Firewall (External)	-	192.168.10.254/24
4	Perimeter Firewall (Internal)	VLAN 20 (DMZ)	10.0.10.1/24
5	Internal Firewall (CDE Facing)	-	10.100.1.1/24
6	DMZ	VLAN 20 (DMZ)	10.0.10.10/24
Switches			
7	Switch 1	VLAN 50	10.50.1.2/24
8	Switch 2	VLAN 100	10.100.1.2/24
Cardholder Data Environment			
9	Application Server	VLAN 110	10.100.10.10/24
10	Key Management System (KMS)	VLAN 120	10.100.20.10/24
11	Database	VLAN 130	10.100.30.10/24
Utilities			
12	Jumpbox	VLAN 99	10.50.99.10/24
13	Log Server	VLAN 200	10.200.10.10/24
Departments			
14	Branch Manager	VLAN 51	10.50.51.10/24
15	Operation Manager	VLAN 52	10.50.52.10/24
16	Compliance officer	VLAN 53	10.50.53.10/24
17	Finance Manager	VLAN 54	10.50.54.10/24
18	IT	VLAN 55	10.50.55.10/24
19	IT Security	VLAN 56	10.50.56.10/24

Diagram

PCI-DSS SCOPE



What will be included in but didn't have in diagram :

- Anti-Malware Solution
- Built-in Network Time Protocol
- Domain Name System

Data Schema

1. **Users_Auth** (Authentication Profile Table) : verify user identity

- **User_ID** (Integer, Primary Key)
- **Username** (String)
- **Password_Hash** (String, Argon2 & bcrypt)
- **User_Role** (String: e.g., 'Client', 'SecurityAdmin', ...)

2. **Transactions** (Secure Payment Storage Table) : store records securely

- **Tx_ID** (Integer, Primary Key)
- **User_ID** (Integer, Foreign Key linking to Users_Auth)
- **Tx_Amount** (Decimal / Float)
- **Masked_PAN** (String - e.g., "4111-11XX-XXXX-1111")
- **Card-Token** (String - Unique reference identifier from KMS)
- **Encrypted_CHD** (Text block - The AES-256 encrypted raw card details payload)
- **Tx_Timestamp** (DateTime)

Log Collecting

Component	Reasons
Perimeter & Internal Firewalls	Drop logs and successful configuration changes
Jumpbox Server	All SSH/RDP connection attempts, session lengths, authentication successes, and failures
Application Server	User authentication cycles, application failures, and API interaction timestamps
Key Management Service (KMS)	Key generation, key access attempts
Database Server	R & R Logins

Planning and Procedure (Brief)

- Week 6 : Build the core routed topology with VLANs, switches, and firewalls.
- Week 7 : Enforce micro-segmentation rules and inter-VLAN routing.
- Week 8 : Developing Application Payment Service Securely and building DB
- Week 9 : Deploy the Linux-based servers and implement the basic application logic
- Week 10 : Demonstrate that only IT/IT Security can authenticate to Jumpbox, then pivot into CDE
- Week 11 : End-to-end data flow from POS (simulated) to DB, with all controls active
- Week 12 : Finalizing Report

All Tasks

ID	Task Name	Duration
Category A: Core Network & Infrastructure		
A01	Configure Switch 1 (Department VLAN)	
A02	Configure Switch 2 (CDE segmentation)	
A03	Configure Firewalls Inbound and Outbound	
A04	Provision Perimeter Firewall Vlan10, Vlan20	
A05	Provision Internal Firewall CDE and Logs	
Category B: Security Controls & Firewall Rules		
B01	ACLs to isolate each department	
B02	Configure Switch 1 to have all OOS to be able to reach Jumpbox	
B03	Implement Tunnel TLS1.2 from Retailer to DMZ	
B04	Configuring App Server to exclusively bidirectional to KMS & DB	
B05	Enforce Deny By Default to firewalls and Switch 1	
Category C: Systems & Identity Access Management (IAM)		
C01	Deploy Jumpbox and have static IP of it (10.50.99.10)	
C02	Hardening Jumbox server	
C03	Implementing MFA to the Jumpbox server	
C04	Deploy Logging Server indirect pipeline	
Category D: Database & Application Development		
D01	Provisioning Database Roles and Set up PostgreSQL	

D02	Initialize Schema and Create storing database	
D03	Integrating Key Management System	
D04	Develop Application Server to catch inbound from DMZ	
D05	Integrate Application Server to handle outbound API requests to KMS	
D06	Program the Application Server data persistence layer to write masked PANs, tokens, and encrypted ciphertext payloads to the DB	
D07	POS transaction payload generation script development	
Category E: Integration, Testing & End-to-End Validation		
E01	Conduct Nmap Scan to verify the isolation	
E02	MFA verification integration	
E03	Prove the default deny on CDE and auto reject from KMS and DB if not originate from Application Server	
E04	Simulation : POS purchase, trace it through the DMZ and App Server, and confirm tokenized storage in the DB	
E05	Audit Log Validation : login, firewall drops, ssh remote, DB queries	
Category F: Documentation & Reporting (Final Phase)		
F01	Finalizing Report	

Appendix

- OOS : Out of scope
- CDE : Cardholder Data Environment
- POS : Point-of-Sale